

Задание 2. Анализ инцидентов информационной безопасности (25 баллов).

Анализ инцидентов информационной безопасности

Исходные данные

Во время проведения внутренней кампании по моделированию фишинговых атак несколько сотрудников открыли учебную страницу аутентификации и ввели корпоративные учетные данные.

Смоделируем ситуацию при которой это было не внутреннее тестирование сотрудников, а действительный боевой фишинг и произошла утечка корпоративных учетных данных.

Необходимо провести анализ каждого инцидента.

Задача

Для каждого сотрудника подготовить аналитическое заключение (1 – 5 стр).

В отчете необходимо определить:

1. Уровень критичности инцидента

Определить уровень риска:

- Низкий
- Средний
- Высокий
- Критический

Необходимо кратко обосновать принятое решение.

2. Возможные последствия компрометации

Необходимо описать возможные действия злоумышленника после получения учетной записи.

3. Приоритет реагирования

Определить:

- требуется ли немедленная реакция;
- необходимо ли привлечение ИТ-службы;
- необходимо ли уведомление руководства;

- требуется ли проведение расследования.

5. Срок устранения

Для каждого мероприятия определить рекомендуемый срок выполнения.

Например

Мероприятие	Срок
Блокировка учетной записи	немедленно
Смена пароля	до 30 минут
Анализ журналов	до 4 часов
Проверка почтовых правил	до 1 рабочего дня
Полное расследование	до 3 рабочих дней

6. Рекомендации по предотвращению повторения

Предложить меры по снижению вероятности повторного возникновения инцидента.

Инцидент №1

Руководитель отдела архитектуры и проектирования (помещений, не it) и отвечает за открытие новых магазинов, офисов и всех площадей компании, работает в управляющей компании.

Во время проведения внутреннего антифишингового тестирования сотрудник получил учебное фишинговое письмо, открыл страницу авторизации и ввел корпоративные учетные данные.

Сотрудник является руководителем подразделения.

Установлено членство в следующих группах безопасности:

- Руководители
- GG_proxy_exclude
- GG_Yandex_360
- Руководители УК
- 1С ЗУП
- 1С Документооборот
- GG_Profiles_Drive
- Все сотрудники центрального офиса
- gg_fserv_Katar
- klinik_tech
- gg_fserv_dis
- vpn-default
- vpn-common-services
- gg_fserv_expluatacia
- cllinik_arch@cllinik.ru
- all_office@cllinik.ru
- GG_Print_Office_Development
- GG_Scan_Office_Development

Инцидент №2

Специалист технической поддержки (первая линия технической поддержки сотрудников (ИТ))

Во время проведения внутреннего антифишингового тестирования сотрудник получил учебное фишинговое письмо, открыл страницу авторизации и ввел корпоративные учетные данные.

По результатам анализа цифровой идентичности установлено наличие доступа к следующим системам:

- ДЭИТ-Disable-Pass
- ll_conflu_access_it
- ll_jira_access_it
- leads_net
- unspot_users
- LL_care_full_access
- qv_programdata_qliktech_documents_prodazhi_rw
- LL_ActiveSync_users
- LL_bitrix_users
- LL_Yandex_360
- vault-marketplaces-firstline
- 2_MFA
- Все сотрудники ИТ
- cc-operators
- ekb-superset-sdk
- expressUsers
- ll_fserv_it_1stlinesupport_fareast
- LL_Profiles_Drive
- vpn-vdi-access
- ll_fserv_doc_callcenter_r
- RDS-SRV-C-ADM
- RDS-SRV-S-ADM
- RDS-SRV-A-ADM
- LL_PortalAD_UsersQR
- RDS-RemoteSession
- CONS-USR-ConsultantRegion
- LL_FIRST_LINE_FOUNDED
- LL_PortalAD_UsersRO
- LL_RMS_IT
- ll_fserv_dis
- ekb_local_admins

- Roaming_profile_fserv
- ll_fserv_dis_cert
- ll_fserv_doc_it_Support
- LL_FIRST_LINE_GRAFANA_EDITORS
- VDIbeeline_Administrator
- vpn-co-services
- LL_FIRST_LINE_GITLAB_ENTRY
- vpn-it-support
- LL_FIRST_LINE_FSERV_RIGHTS_FOR_GROUPS
- LL_vcenter_First_line
- Первая линия ИТ
- RDS_DepAccounting
- LL_Firstline_Admin_Core_Servers
- ds_restart_containers_sudo
- EKB_CO_ITInfrastructureSupplImpl_Avarii_RW
- EKB_CO_CC_USER_ALL_AsterCallc
- git_users
- all_office@kuol.ru
- Все сотрудники ИТ РФ
- RDS_RemoteApp_Access
- llrafanaViewer
- LL_Scan_Office_IT
- LL_CO_IT_Department_Ekb
- LL_DiscountCampaignCreator
- OTRS_TechSupport
- LL_Fserv_IT_SysAdmins
- LL_CO_IT_Department
- SD Restricted

Административные права уровня Active Directory отсутствуют.

Учетная запись обладает расширенным техническим доступом к инфраструктуре организации.

Инцидент №3

Кладовщик

Во время проведения внутренней кампании моделирования фишинговых атак сотрудник открыл ссылку из письма и ввел корпоративные учетные данные.

Пользователь является членом следующих групп:

- GG_ActiveSync_users
- GG_Yandex_360
- Контур 2FA
- Kontur_MFA
- 910_BRK

По результатам анализа цифровой идентичности установлено наличие доступа к:

- корпоративной электронной почте;
- Microsoft ActiveSync;
- Яндекс 360;
- электронному документообороту Контур.

Доступ к VPN, файловым серверам, ERP, системам разработки, административным сервисам и инфраструктурным ресурсам отсутствует.

Требования к оформлению

Результаты необходимо предоставить в виде отчета в формате Word или PDF.

Для каждого инцидента должно быть подготовлено самостоятельное аналитическое заключение.